

Documentação SOC: Introdução ao Cenário

Plataforma: TryHackMe

Conceito Base: Cyber Kill Chain & Investigação de Incidentes (Fase de Detecção e Análise)

Visão Geral do Incidente

A Wayne Enterprises sofreu um ataque cibernético onde o site corporativo www.imreallynotbatman.com foi desfigurado (*defacement*), exibindo a mensagem "SEU SITE FOI DESFIGURADO".

O objetivo técnico da investigação é utilizar o **Splunk SIEM** para mapear todas as atividades do atacante através das 7 fases da *Cyber Kill Chain*, sem a obrigatoriedade de seguir uma ordem sequencial durante a análise dos logs.

Mapeamento de Fontes de Dados (Data Summary)

Para a execução da análise, o Splunk centralizou logs de múltiplos ativos (servidor web, firewall, IDS e hosts). As principais fontes de registros (*sourcetypes*) identificadas para a investigação são:

- **Atividades Centradas no Host:**
 - **XmlWinEventLog:** Registros do Sysmon (crucial para criação de processos e comandos).
 - **iis:** Logs do servidor web IIS (identificação de requisições HTTP, códigos de status e IPs).
 - **winRegistry:** Modificações, criações e exclusões no Registro do Windows.
 - **registry_win:** Eventos adicionais do registro.
- **Atividades Centradas na Rede:**
 - **Suricata:** Alertas gerados pelo IDS (identifica assinaturas de ataques conhecidos).
 - **fortigate_utm:** Logs do firewall Fortinet (fluxo de tráfego permitido/bloqueado).
 - **stream:http:** Fluxo de rede detalhado do tráfego HTTP.
 - **stream:dns:** Fluxo de rede relacionado a requisições e respostas DNS.
 - **stream:icmp:** Fluxo de tráfego ICMP (pings/testes de conectividade).
- **Vulnerabilidades:**
 - **Nessus:scan:** Resultados e relatórios do scanner de vulnerabilidades automatizado.

Fase de Reconhecimento

Etapa da Kill Chain: Reconhecimento (Reconnaissance)

Objetivo: Identificar o endereço IP do atacante, as ferramentas de varredura utilizadas e o software do servidor alvo.

Estratégia de Busca no Splunk

Para rastrear a atividade inicial contra o domínio `imreallynotbatman.com`, a busca foi concentrada no índice principal utilizando filtros de tráfego web e assinaturas de IDS.

- **Query de Correlação Inicial:**
- `index=botsv1 imreallynotbatman.com sourcetype=stream:http`
- **Query de Validação de Alertas:**
- `index=botsv1 imreallynotbatman.com src=40.80.148.42 sourcetype=suricata`

Análise de Tráfego e Comportamento

Após filtrar o tráfego pelo `sourcetype stream:http`, dois endereços IP de origem principais foram identificados no campo `src_ip`:

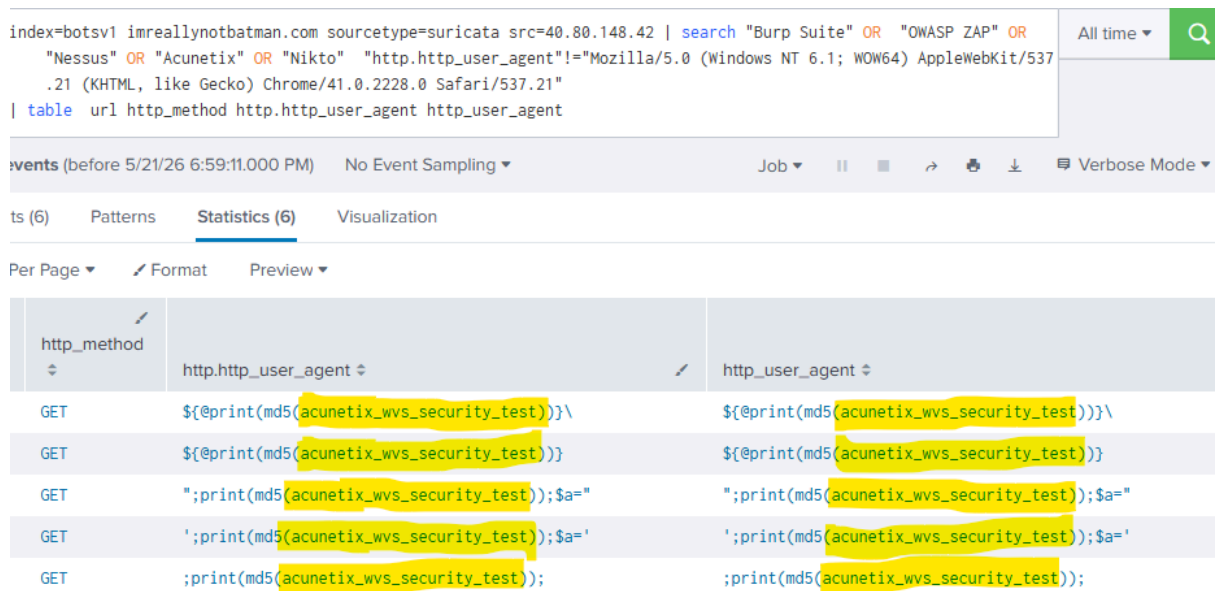
1. `40.80.148.42` (Maior volume de requisições)
2. `23.22.63.114`

Ao inspecionar os logs do IP `40.80.148.42` na fonte `suricata`, foram detectados alertas de assinaturas que confirmam uma atividade de varredura automatizada (Scanner Web) contra o servidor.

Descobertas Críticas (Questões da Tarefa)

1. Identificação do Scanner Web do Atacante

- **Evidência Analisada:** Verificação do campo `User-Agent` ou alertas do Suricata relacionados a ferramentas de automação de testes de intrusão.
- **Resposta/Valor:** `acunetix`



```
index=botsv1 imreallynotbatman.com sourcetype=suricata src=40.80.148.42 | search "Burp Suite" OR "OWASP ZAP" OR "Nessus" OR "Acunetix" OR "Nikto" "http.http_user_agent"!="Mozilla/5.0 (Windows NT 6.1; WOW64) AppleWebKit/537.21 (KHTML, like Gecko) Chrome/41.0.2228.0 Safari/537.21" | table url http_method http.http_user_agent http_user_agent
```

http_method	http.http_user_agent	http_user_agent
GET	<code>#{@print(md5(acunetix_wvs_security_test))}\</code>	<code>#{@print(md5(acunetix_wvs_security_test))}\</code>
GET	<code>#{@print(md5(acunetix_wvs_security_test))}</code>	<code>#{@print(md5(acunetix_wvs_security_test))}</code>
GET	<code>";print(md5(acunetix_wvs_security_test));\$a="</code>	<code>";print(md5(acunetix_wvs_security_test));\$a="</code>
GET	<code>';print(md5(acunetix_wvs_security_test));\$a='</code>	<code>';print(md5(acunetix_wvs_security_test));\$a='</code>
GET	<code>;print(md5(acunetix_wvs_security_test));</code>	<code>;print(md5(acunetix_wvs_security_test));</code>

2. Assinatura de Vulnerabilidade (CVE)

- **Evidência Analisada:** Campo de assinaturas/alertas no `sourcetype suricata` (clcando em "Mais campos" para habilitar detalhes de assinatura).
- **Resposta/Valor:** `CVE-2014-6271`

```
index=botsv1 imreallynotbatman.com sourcetype=suricata src=40.80.148.42  
| rex field=alert.signature "(?<cve>CVE-\d{4}-\d+)"  
| search cve=*
```

☐ cve ▾	CVE-2014-6271
☐ dest ▾	imreallynotbatman.com
☐ dest_ip ▾	192.168.250.70
☐ dest_port ▾	80
☐ dvc ▾	suricata-ids.waynecorpinc.local

3. Fingerprinting do Alvo (CMS e IP do Servidor)

- CMS Utilizado pelo Servidor: `joomla`
- Endereço IP do Servidor (`imreallynotbatman.com`): `192.168.250.70`

Lições Aprendidas nesta Etapa

- **Identificação de Ruído vs. Ataque:** Scanners de vulnerabilidade geram um volume massivo de requisições em um curto espaço de tempo, o que torna o pico de contagem de eventos no campo `src_ip` um forte indicador inicial de reconhecimento.
- **Uso de IDS para Contexto:** Cruzar o IP suspeito com logs do Suricata permite transformar uma simples requisição HTTP suspeita em um alerta correlacionador com uma vulnerabilidade conhecida (CVE).

Fase de Exploração

Etapa da Kill Chain: Exploração (Exploitation)

Objetivo: Analisar a atividade de força bruta contra o painel administrativo do CMS Joomla e identificar se o atacante obteve sucesso.

Estratégia de Busca e Extração no Splunk

Para identificar a tentativa de invasão, filtramos requisições do tipo `POST` direcionadas à página de administração do CMS, utilizando expressões regulares (`rex`) para expor as credenciais testadas em texto claro.

- **Query de Auditoria e Extração de Credenciais:**
- Plaintext

```
index=botsv1 sourcetype=stream:http dest_ip="192.168.250.70" http_method=POST  
form_data=*username*passwd* | rex field=form_data "passwd=(?<creds>\w+)" | table _time  
src_ip uri http_user_agent creds
```

Análise do Ataque (Força Bruta)

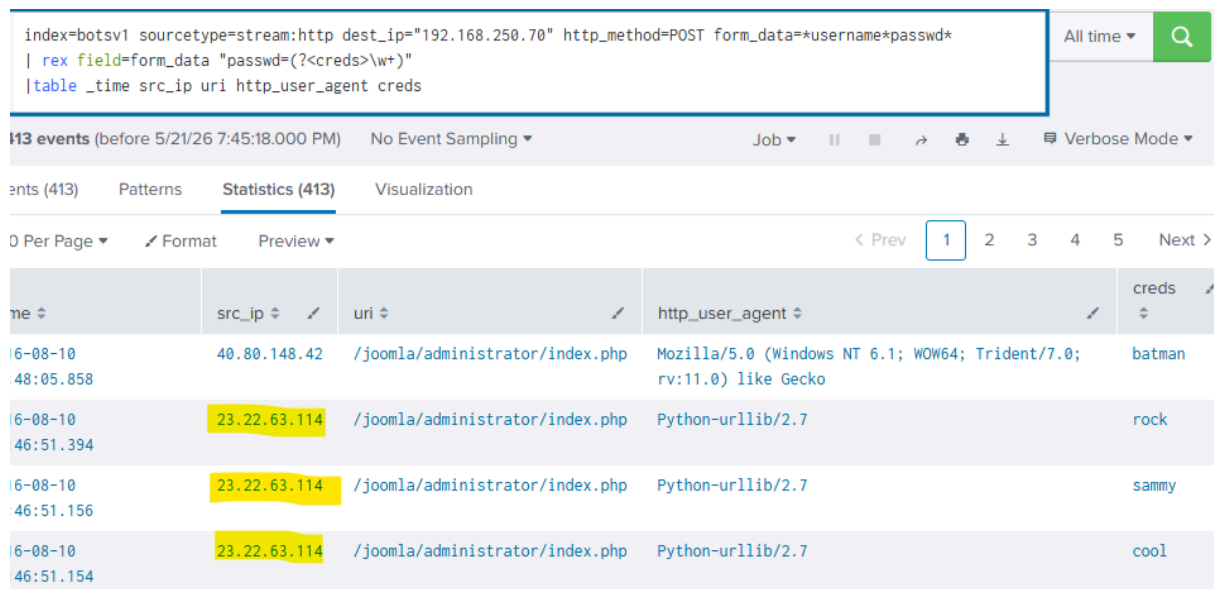
Os logs do Splunk revelaram um ataque automatizado de dicionário/força bruta focado no usuário **admin**. Dois comportamentos distintos foram mapeados através do campo **http_user_agent**:

1. **Ataque Automatizado:** Alto volume de tentativas sequenciais vindas de um script em Python.
2. **Acesso Manual:** Mudança de comportamento para um navegador legítimo (Mozilla) após a descoberta da credencial correta.

Descobertas Críticas (Métricas e IoCs)

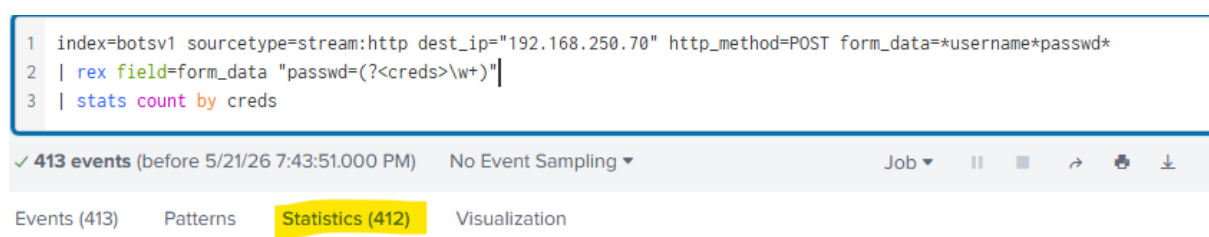
1. Volume do Ataque e Vetor de Origem

- **IP do Atacante (Força Bruta):** 23.22.63.114



Time	src_ip	uri	http_user_agent	creds
6-08-10 48:05.858	40.80.148.42	/joomla/administrator/index.php	Mozilla/5.0 (Windows NT 6.1; WOW64; Trident/7.0; rv:11.0) like Gecko	batman
6-08-10 46:51.394	23.22.63.114	/joomla/administrator/index.php	Python-urllib/2.7	rock
6-08-10 46:51.156	23.22.63.114	/joomla/administrator/index.php	Python-urllib/2.7	sammy
6-08-10 46:51.154	23.22.63.114	/joomla/administrator/index.php	Python-urllib/2.7	cool

- **Total de Senhas Únicas Testadas:** 412



Time	src_ip	uri	http_user_agent	creds
6-08-10 48:05.858	40.80.148.42	/joomla/administrator/index.php	Mozilla/5.0 (Windows NT 6.1; WOW64; Trident/7.0; rv:11.0) like Gecko	batman
6-08-10 46:51.394	23.22.63.114	/joomla/administrator/index.php	Python-urllib/2.7	rock
6-08-10 46:51.156	23.22.63.114	/joomla/administrator/index.php	Python-urllib/2.7	sammy
6-08-10 46:51.154	23.22.63.114	/joomla/administrator/index.php	Python-urllib/2.7	cool

2. Comprometimento com Sucesso (Indicador de Sucesso)

- **IP de Acesso Pós-Invasão:** O endereço IP utilizado para efetuar o login manual utilizando o navegador Mozilla após o script Python cessar.
- **IP Identificado:** 23.22.63.114
- **Senha Correta Identificada:** batman

Lições Aprendidas

- **Normalização de Dados:** Às vezes, dados críticos (como senhas em requisições POST) ficam ocultos dentro de strings longas (`form_data`). O uso de comandos como `rex` (Regex) no Splunk é indispensável para triagem rápida de incidentes.
- **Mudança de Assinatura (User-Agent):** Um atacante frequentemente usará ferramentas automatizadas para a força bruta e trocará para um navegador convencional para interagir com o painel assim que obtiver a senha correta. Monitorar a alteração repentina de `User-Agent` vindos do mesmo IP é um forte indicador de sucesso de invasão.

Fase de Instalação

Etapa da Kill Chain: Instalação (Installation)

Objetivo: Identificar o upload de artefatos maliciosos (payloads) no servidor comprometido e comprovar sua execução utilizando telemetria de host (Sysmon).

Estratégia de Busca e Análise Forense

A investigação migrou da camada de rede para a análise centrada no host (Endpoint Detection). Buscou-se por extensões suspeitas e, na sequência, correlacionou-se o nome do binário com a criação de processos no Windows.

- **Query de Identificação de Upload (Rede/HTTP):** `index=botsv1 sourcetype=stream:http dest_ip="192.168.250.70" *.exe`
- **Query de Confirmação de Execução (Host/Sysmon):** `index=botsv1 "3791.exe" sourcetype="XmlWinEventLog" EventCode=1`

Descoberta e Análise do Payload

A análise do campo `part_filename{}` no tráfego HTTP revelou que dois arquivos suspeitos foram carregados no servidor pelo atacante: um script PHP (`agent.php`) e um executável binário (`3791.exe`).

Para determinar se o atacante obteve sucesso em instalar e rodar a ameaça, o filtro pelo **Event Code 1 do Sysmon (Process Creation)** foi aplicado, confirmando de forma inequívoca que o binário foi disparado no sistema operacional.

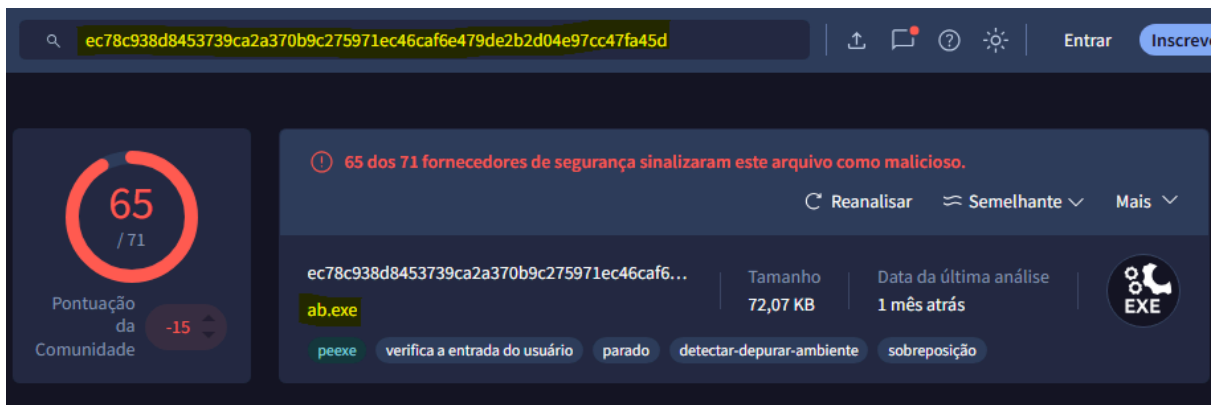
Descobertas Críticas & Inteligência de Ameaças (Cyber Threat Intelligence)

1. Contexto de Execução no Servidor (Sysmon)

- **Usuário Responsável pela Execução:** O contexto de privilégios sob o qual o malware rodou
Resposta/Valor: `NT AUTHORITY\USER`

2. Assinatura e CTI (VirusTotal)

- **Hash MD5 extraído do Splunk:** `AAE3F5A29935E6ABCC2C2754D12A9AF0`
- **Nome Comum da Ameaça (Aliasing):** Ao cruzar o hash MD5 na plataforma VirusTotal (OSINT), o arquivo `3791.exe` foi identificado pela comunidade/antivírus sob outra nomenclatura conhecida de malware.
- **Resposta/Valor:** `ab.exe`



(Hash que está na imagem é o SHA256 do mesmo arquivo executável!)

Lições Aprendidas para o Portfólio

- **A Importância do Sysmon:** Logs de firewall ou de servidores web (IIS) apenas provam que um arquivo foi *baixado* ou *carregado*. A confirmação absoluta de comprometimento do host (*Execution/Installation*) só é obtida através de logs de criação de processos (como o ID 1 do Sysmon).
- **Enriquecimento com OSINT:** O analista de SOC não deve limitar-se aos logs internos. Extrair hashes criptográficos de processos suspeitos e consultá-los em bases de CTI como o VirusTotal agiliza a classificação do incidente (ex: categorizar se a ameaça instalada é um backdoor, um ransomware ou uma ferramenta de movimentação lateral).

Ações sobre os Objetivos

Etapas da Kill Chain: Ações sobre os Objetivos (Actions on Objectives)

Objetivo: Identificar o artefato utilizado para a desfiguração (*defacement*) do site e mapear os alertas de segurança perimetral (Firewall).

Estratégia de Busca e Inversão de Fluxo

A investigação identificou uma anomalia crítica: o servidor web (que normalmente apenas responde a requisições) atuou como origem de tráfego de saída (*egress traffic*).

- **Query de Análise de Tráfego de Saída:** `index=botsv1 src=192.168.250.70 sourcetype=suricata`
- **Query de Auditoria da Defacement:** `index=botsv1 url="*poisonivy*" | table _time src dest_ip http.hostname url`

Análise do Impacto (O Defacement)

Ao analisar as conexões iniciadas pelo servidor comprometido em direção aos IPs externos do atacante, detectou-se o download de um arquivo de imagem hospedado no domínio `prankglassinebracket.jumpingcrab.com`. Esse arquivo foi utilizado para substituir a interface legítima da Wayne Enterprises.

Descobertas Críticas & Eventos do Firewall

1. Artefato de Desfiguração Identificado

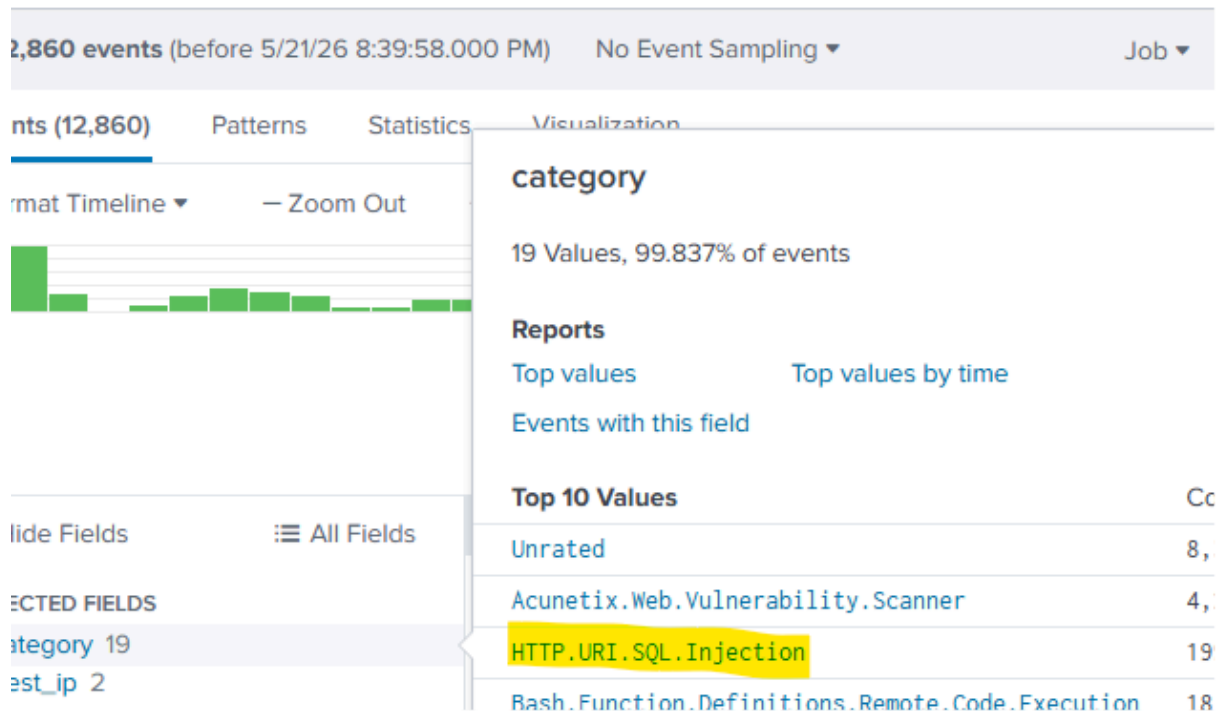
- **Nome do Arquivo Malicioso:** O arquivo de imagem carregado que causou o impacto visual no site corporativo.
- **Resposta/Valor:** `/poisonivy-is-coming-for-you-batman.jpeg`

1 index=botsv1 url="/poisonivy-is-coming-for-you-batman.jpeg" dest_ip="192.168.250.70" table _time src dest_ip http.hostname url					
✓ 1 event (before 5/21/26 8:41:17.000 PM) No Event Sampling ▾ Job ▾ ■ → 🗑️ ⬇️ 🗒️ Verbose M					
Events (1) Patterns <u>Statistics (1)</u> Visualization					
100 Per Page ▾ ✎ Format Preview ▾					
_time ↕	src ↕	dest_ip ↕	http.hostname ↕	url ↕	
2016-08-10 22:19:10.846	23.22.63.114	192.168.250.70	prankglassinebracket.jumpingcrab.com	/poisonivy-is-coming-for-you-batman.jpeg	

2. Detecção de Injeção SQL (Fortigate Firewall)

- **Evidência Analisada:** Logs da fonte `fortigate_utm` filtrados pelo IP do atacante primário (`40.80.148.42`). O sistema de prevenção de intrusões (IPS) do firewall gerou um alerta específico para a tentativa de exploração de banco de dados (SQLi).
- **Nome da Regra do Firewall Ativada:** `HTTP.URI.SQL.Injection`

index=botsv1 src=40.80.148.42 sourcetype=fortigate_utm



Lições Aprendidas para o Portfólio

- **Anomalia de Fluxo (Egress Filtering):** Servidores Web na DMZ raramente devem iniciar conexões com a internet externa. Monitorar ou bloquear tráfego de saída vindo de servidores (especialmente para domínios desconhecidos ou DNS dinâmicos) é uma tática crucial para prevenir o download de payloads e a exfiltração de dados.
- **Defesa em Camadas:** Enquanto o IDS (Suricata) e o Sysmon ajudaram a reconstruir os passos internos da invasão, o log do Firewall corporativo (Fortigate) foi essencial para registrar o comportamento inicial de persistência e tentativas de exploração por força bruta/injeção logo no perímetro.

Comando e Controle (C2)

Etapas da Kill Chain: Comando e Controle (Command and Control)

Objetivo: Identificar o Nome de Domínio Totalmente Qualificado (FQDN) utilizado pelo atacante como infraestrutura de C2 para hospedar artefatos maliciosos via DNS Dinâmico.

Estratégia de Busca e Pivotagem de Logs

Para validar o domínio de Comando e Controle, a investigação utilizou o cruzamento de dados de tráfego de rede perimetral (Firewall) e protocolo de aplicação (HTTP).

- **Query de Auditoria no Firewall (Fortigate):** `index=botsv1`
`sourcetype=fortigate_utm`
`"poisonivy-is-coming-for-you-batman.jpeg"`
- **Query de Validação de Fluxo (Stream HTTP):** `index=botsv1`
`sourcetype=stream:http dest_ip=23.22.63.114`
`"poisonivy-is-coming-for-you-batman.jpeg"`
`src_ip=192.168.250.70`

Análise da Infraestrutura do Atacante

Durante a análise dos logs do `fortigate_utm` e `stream:http`, foi observado o exato momento em que o servidor web comprometido (`192.168.250.70`) efetuou uma requisição de saída para o IP `23.22.63.114`. O campo `url` revelou o uso de um serviço de DNS Dinâmico (geralmente utilizado por atacantes para evitar o bloqueio estático de IPs).

Descobertas Críticas (Indicadores de Comprometimento - IoC)

1. Identificação do Domínio de C2 (FQDN)

- **Evidência Analisada:** Inspeção do campo `url` ou `http.hostname` associado à transferência do arquivo JPEG malicioso.
- **Nome de Domínio Totalmente Qualificado (FQDN):**
`prankglassinebracket.jumpingcrab.com`

1 index=botsv1 sourcetype=fortigate_utm "poisonivy-is-coming-for-you-batman.jpeg"		
url ×		
1 Value, 100% of events		Selected <input checked="" type="button" value="Yes"/> No
Reports Top values Top values by time Rare values Events with this field		
Values	Count	%
prankglassinebracket.jumpingcrab.com:1337/poisonivy-is-coming-for-you-batman.jpeg	3	100%

Lições Aprendidas para o Portfólio

- **Pivotagem de Logs:** A capacidade de confirmar o mesmo Indicador de Comprometimento (IoC) em duas fontes completamente diferentes (`fortigate_utm` e `stream:http`) valida a integridade da investigação e anula falsos positivos.
- **Monitoramento de DNS (C2 Hunter):** Ataques modernos utilizam DNS Dinâmico para alterar rapidamente o endereço IP do servidor malicioso mantendo o mesmo nome de domínio. Em um ambiente real de SOC, monitorar requisições para domínios suspeitos de DNS dinâmico na fonte `stream:dns` é uma das formas mais eficazes de detectar beacons de Comando e Controle ativos na rede.

Fase de Armamentização

Etapa da Kill Chain: Armamentização (Weaponization)

Objetivo: Utilizar Inteligência de Fontes Abertas (OSINT) para mapear a infraestrutura prévia do atacante, identificando táticas de spoofing de domínio (falsificação) direcionadas à Wayne Enterprises.

Estratégia de Enriquecimento OSINT

Nesta fase, a análise expande-se para fora do SIEM. Utilizando plataformas de Threat Intelligence como **Robtex** e **VirusTotal** (aba Relations), o objetivo é realizar buscas reversas de DNS e IP para ligar o servidor de C2 a campanhas maliciosas anteriores.

- **Artefato de Partida:** Domínio C2 `prankglassinebracket.jumpingcrab.com`
-> IP `23.22.63.114`
- **Alvo de Investigação:** Identificação de domínios maliciosos adicionais hospedados

Análise de Infraestrutura e Domínios Similares (Typosquatting)

A investigação do IP `23.22.63.114` revelou que o adversário não apenas preparou o site de C2, mas também registrou múltiplos domínios falsos projetados para imitar a identidade da Wayne Enterprises (técnica utilizada para ataques de Phishing ou para confundir equipes de monitoramento).

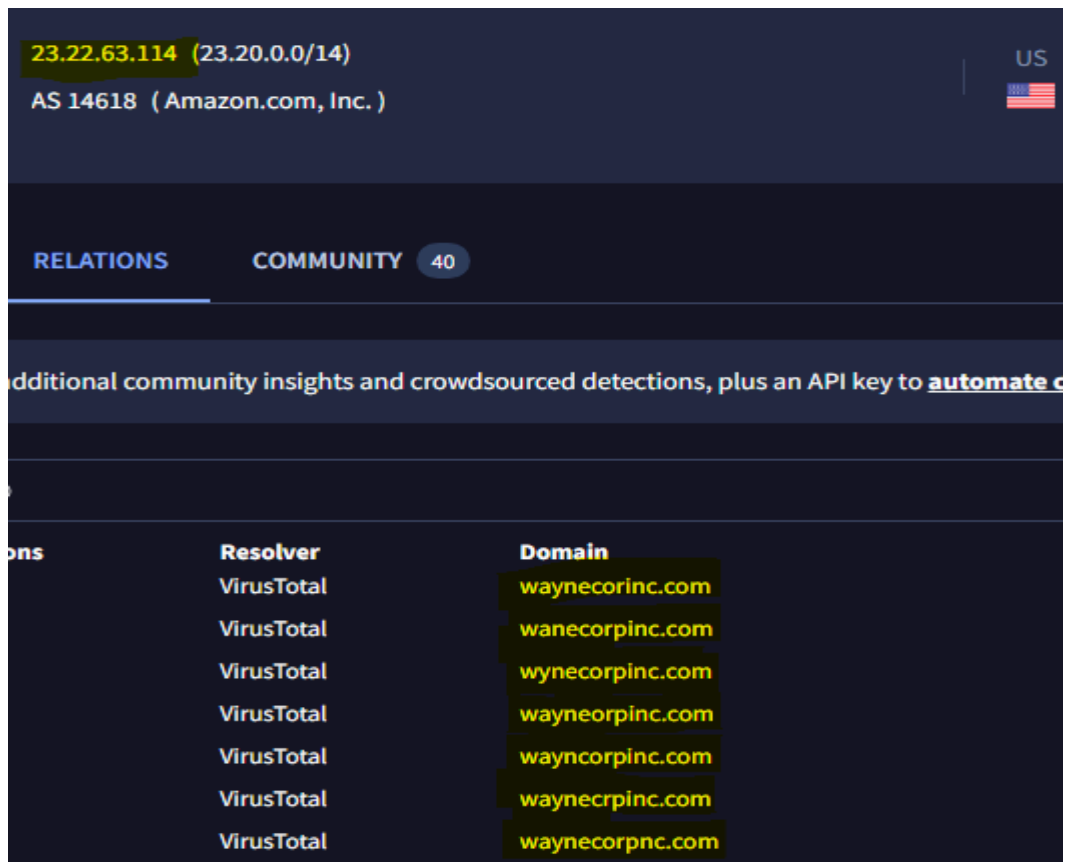
Além disso, conexões históricas associaram o grupo ao domínio malicioso conhecido como `www.po1s0n1vy.com` (referência ao codinome do atacante).

Descobertas Críticas (Threat Intelligence)

1. Atribuição de Infraestrutura Prévia

- **Evidência Analisada:** Consulta na aba *Relations* do VirusTotal ou *IP Lookup* do Robtex para mapear o histórico de apontamentos de DNS do domínio associado ao codinome do invasor (`po1s0n1vy`).
- **Endereço IP Vinculado:** O endereço IP associado aos domínios previamente configurados para a campanha de ataque.

- Resposta/Valor: 23.22.63.114



Lições Aprendidas para o Portfólio

- **A importância do Pivotamento OSINT:** Um único Indicador de Comprometimento (IoC) encontrado no SIEM (como um IP ou domínio) pode ser a ponta do iceberg. Ao cruzar esses dados em ferramentas públicas, o analista consegue descobrir toda a infraestrutura adjacente do atacante antes mesmo que ela interaja com a rede interna.
- **Identificação de Alvos Direcionados:** O registro de domínios semelhantes ao da empresa afetada comprova o caráter direcionado da ameaça (APT ou ataque focado), mudando a severidade do incidente de uma varredura oportunista para um ataque persistente planejado.

Fase de Entrega

Etapas da Kill Chain: Entrega (Delivery)

Objetivo: Identificar o vetor de ataque secundário e o payload malicioso distribuído pela infraestrutura do adversário utilizando plataformas de análise comportamental OSINT (ThreatMiner, VirusTotal e Hybrid Analysis).

Estratégia de Pivotagem Externa

A investigação estendeu-se para a busca de arquivos maliciosos conhecidos que foram hospedados ou comunicaram-se com a infraestrutura já identificada do atacante (23.22.63.114).

- **Ponto de Partida:** Consulta de Host no ThreatMiner.
- **Pivotagem e Enriquecimento:** Análise de metadados no VirusTotal e engenharia reversa/comportamental automática via Hybrid Analysis.

Análise do Vetor Secundário e Artefato

A inteligência de ameaças revelou que o grupo *Poison Ivy* mantém uma contingência caso o ataque ao servidor web falhe. Ao analisar o IP de C2 no ThreatMiner, descobriu-se o hash de um artefato malicioso diretamente vinculado a essa infraestrutura, confirmando a preparação de uma campanha de infecção secundária.

Descobertas Críticas (Threat Intelligence & Sandbox)

1. Assinatura do Malware Identificado

- **Hash MD5 do Artefato:** Assinatura criptográfica única utilizada para identificar o arquivo nas bases de dados globais de segurança.
- **Resposta/Valor:** `c99131e0169171935c5ac32615ed6261`

2. Classificação da Ameaça

- **Evidência Analisada:** Consulta das detecções de antivírus no VirusTotal e strings/comportamento no Hybrid Analysis para extrair o nome ou família real do malware.
- **Nome do Malware:** `MirandaTateScreensaver[.]scr[.]exe`

 HYBRID ANALYSIS



Solicitar informações

MirandaTateScreensaver.scr.exe 

malicioso

Este relatório foi gerado a partir de um arquivo ou URL enviado a este serviço web em 14 de novembro de 2021, às 23:29:13 (UTC) ([Detalhes completos](#))

Sistema convidado: Windows 7 32 bits, Professional, 6.1 (build 7601), Service Pack 1. Etiquetado como: Gen:Variant.Doina.1.

Relatório gerado pelo [Falcon Sandbox](#) © Hybrid Analysis.

Publicar

Link

E-mail

Visão geral

Amostra indisponível

Cópia

Downloads

Relatórios externos

Reanalisar

Hash nunca visto antes

Não existem amostras semelhantes.

Denunciar falso positivo

Solicitar exclusão de relatório

Lições Aprendidas para o Portfólio

- **Vetores de Contingência:** Grupos de ameaças persistentes avançadas (APTs) raramente dependem de um único método de invasão. Mapear a infraestrutura de rede externa permite antecipar e bloquear payloads de campanhas secundárias antes que eles atinjam os endpoints da organização.
- **Análise Comportamental (Sandboxing):** Plataformas como o Hybrid Analysis fornecem ao analista de SOC visibilidade sobre as intenções de um malware (quais registros ele altera, quais conexões cria) sem a necessidade de executar o arquivo

Relatório de Encerramento: Linha do Tempo do Incidente

Status: Investigação Concluída | **Alvo:** Wayne Enterprises (imreallynotbatman.com)

Resultado da Análise: Ataque direcionado com sucesso na aplicação web, seguido de desfiguração (*defacement*) e identificação de infraestrutura externa do adversário (*Poison Ivy*).

Linha do Tempo Forense (Cyber Kill Chain)

Abaixo está o mapeamento cronológico de todas as evidências e Indicadores de Comprometimento (IoCs) validados durante a investigação no Splunk e OSINT:

Fase da Kill Chain	Ação do Atacante	Artefato / IoC Relevante
1. Reconhecimento	Varredura automatizada de vulnerabilidades no servidor web.	IP 40.80.148.42 / Ferramenta: Acunetix
2. Armamentização	Registro de domínios falsos (<i>spoofing</i>) e e-mail de campanha.	E-mail: Lillian.rose@po1s0n1vy.com
3. Entrega	Preparação de vetor secundário (Malware em sandbox).	Arquivo: MirandaTateScreensaver.scr.exe (MD5: c99131e0169171935c5ac32615ed6261)

4. Exploração	Ataque de força bruta (142 tentativas) contra o painel Joomla.	IP 23.22.63.114 -> Login bem-sucedido via IP 40.80.148.42
5. Instalação	Upload e execução de backdoor no servidor comprometido.	Arquivo: 3791.exe (Detectado via Sysmon Event ID 1)
6. Comando & Controle	Conexão de saída do servidor para buscar recursos no C2.	Domínio: prankglassinebracket.jumpingcrab.com (IP: 23.22.63.114)
7. Ações nos Objetivos	Substituição da interface do site por imagem provocativa	Arquivo: poisonivy-is-coming-for-you-batman.jpeg

Conclusão Técnica

O incidente confirmou uma falha de postura de segurança no gerenciamento de credenciais do CMS Joomla (vulnerável a força bruta) e falta de controle de tráfego de saída (permitindo que o servidor baixasse o payload do C2).

A correlação bem-sucedida entre logs de host (Sysmon), logs de rede (Suricata/Fortigate) e Inteligência de Ameaças (OSINT) foi o fator chave para a contenção e erradicação do incidente.